

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Week 1 Practical Laboratory

Information Security Governance in Action

RABIATU UMAR AHMAD

C11/26/CGRCE/17569

COHORT 11

11th September, 2026

Task 1 Governance Blueprint

1.

Governance Gap	Assessment
Unclear security ownership	Security responsibilities are shared between IT staff and other departments without a specific defined governance owner. This can create gaps in accountability and slow decision-making
Ad-hoc policies and processes	Risk of inconsistent control due to rapid expansion and acquisitions, and its security approach is still largely informal.
Reactive risk management	The recent data-leakage near-miss shows that security issues may be addressed after problems arise rather than through a formal proactive risk assessment process
Weak cross-functional coordination	IT, development, compliance, finance and HR all have security-related responsibilities, but there is no formal structure for resolving competing priorities.
Limited management reporting	There is technical information but not adequately translated into business risk, financial impact or decisions that senior management can easily use
Inconsistent accountability after acquisitions	Policies inherited from acquired organisations may not be aligned, making it difficult to maintain one consistent security standard across GHC

2. Proposed reporting relationship:

Board of Directors



Chief Executive Officer (CEO)



Director of Information Security Governance



Security Steering Committee (SSC)



IT Operations | Development | Legal & Compliance | Finance | HR

The CTO, IT Manager, Senior Developer, Compliance Officer, Finance representative and HR Manager should work with the governance function through the SSC. The Board should receive quarterly security and risk reports.

3.

Activity	Board	CEO	InfoSec Gov	CTO/IT	Compliance	HR/Finance
Security policy approval	I	A	R	C	C	I
Enterprise security risk review	A	A	R	C	C	C
Incident response planning	I	A	R	R	C	C
Security metrics and Board reporting	A	A	R	C	C	I
Security awareness and training	I	A	R	C	C	R
Third-party/security compliance review	I	A	R	C	R	C

R = Responsible, A = Accountable, C = Consulted, I = Informed.

4. The proposed structure improves accountability because each important security activity has an identified owner and an accountable executive. It also improves transparency because the SSC gives report for risks, decisions and unresolved issues. Business alignment is enhanced by involving technology, compliance, finance and HR rather than treating security as an IT-only responsibility. Finally, the structure supports risk management by requiring risks and incidents to be reviewed at management level and escalated when necessary.

Task 2: Information Security Charter

5. i. Purpose:

The purpose of the GHC Information Security Programme is to protect patient information, business information, systems and services also ensuring GHC to grow, innovate and maintain customer trust.

Scope:

The Charter is applicable to GHC employees, contractors, systems, information assets, patient and customer data, financial information. It contains information security governance, risk management, policies, awareness, incident management, compliance and security reporting

Authority

The programme operates under the authority of executive management and the Board.

Roles and Responsibilities

The Board provides oversight and challenges management on significant risks. The CEO provides executive accountability and resources. The Director of Information Security Governance coordinates governance, risk reporting, policy development and oversight. The CTO and IT Manager are responsible for implementing and maintaining appropriate technical and operational controls. The Compliance Officer supports regulatory obligations. HR manages security-related onboarding, offboarding and awareness processes. Finance supports consideration of financial impact and investment decisions.

Key Principles

GHC will apply risk-based, business-aligned, proportionate and continuously improving security. Security decisions should protect sensitive information without unnecessarily preventing innovation.

Reporting Structure

Security governance will report regularly to executive management and the Security Steering Committee. Significant risks, incidents, trends, compliance issues and resource requirements will be escalated to the CEO and Board.

Review and Approval

The Charter will be approved by executive management and reviewed at least annually or sooner when there are major organisational, regulatory, technology or risk changes. Material changes require executive approval and should be communicated to affected stakeholders.

6. Justification for the GHC Information Security Charter

The proposed Information Security Charter gives GHC a report for managing information security and connects security activities to the organisation's 2026 strategic goals. As GHC plans to increase its client base and enter two regional markets, a consistent security governance structure is required to maintain customer confidence and manage the additional risks created by growth and acquisitions. The Charter also supports GHC's

mission of protecting patient information, improving operational efficiency, enabling secure innovation and meeting applicable healthcare and data-protection obligations.

Task 3: Board Reporting and Security Metrics

7. Executive Summary

Overall security posture: RED.

I assessed the current posture as Red because the six-month data shows a continuous increase in phishing, malware and high-risk incidents, while the percentage of critical vulnerabilities patched reduced from 67% to 55%. The training completion improved from 45% to 70%, the improvement has not yet translated into a reduction in security threats or high-risk incidents. The Board should therefore treat the current position as a serious governance issue.

8.

Metric	Six-Month Movement	Trend	Business Commentary
Phishing attempts	150 → 320	Increasing	This shows strong exposure to threats and vulnerabilities. Need strong preventive measures.
Malware events	25 → 50	Increasing	This has doubled which can cause data compromise thereby disrupting the business.
Critical vulnerabilities patched	67% → 55%	Reducing	It has reduced but still possibilities of other weakness to be exploited.
Security training completion	45% → 70%	Increasing	It has increased and has serious positive effect on the behaviors of the users.
High-risk incidents	2 → 7	Increasing	This is the most concerning business indicator because it affect actual high-priority security events

9. i. Increasing high-risk incidents: High-risk incidents increased from 2 in September to 7 in February. This may affect patient-data protection, service availability, reputation and regulatory obligations.
ii. Declining vulnerability remediation: Critical vulnerability patching reduced from 67% to 55%. Known vulnerabilities therefore remain unresolved for longer, increasing the organisation's exposure.
10. i. Increase phishing and incident-prevention measures through vigorous awareness.
ii. Board involvement is very important, prioritising critical vulnerabilities and escalation.

Task 4 Security Steering Committee

11. Purpose

The Security Steering Committee (SSC) will provide cross-functional direction, prioritisation and oversight for information security matters at GHC.

Scope

The SSC will consider security policies, enterprise risks, major incidents, compliance issues requiring cross-functional decisions.

Membership

The Executive Board, Director of Information Security Governance, CTO, IT Manager, Compliance Officer, Senior Developer, Finance representative and HR Manager.

Responsibilities

Resolve cross-functional security issues and escalate significant unresolved matters to the CEO or Board.

Meeting Cadence

The SSC should meet monthly, with additional meetings when a major incident or urgent governance issue requires a decision.

Decision Authority

The SSC may make decisions within its appointed authority. Decisions with significant financial, strategic, regulatory or enterprise-risk implications should be escalated to the CEO or Board.

Reporting

The Director of Information Security Governance will maintain meeting records, decisions and action items. Significant risks, unresolved disagreements and material security issues will be included in executive and Board reporting.

12. Key point:

Password-policy dispute: 16-character complex passwords changed every 30 days compared a balanced approach using MFA and secure password management.

13. The SSC will give GHC a formal forum to resolve the differences. In the password-policy issue, the committee should avoid deciding the issue based only on the opinion of the CTO or IT Manager. Instead, they should focus on comparing the security benefit, user impact, operational advantage and business risk of each option. The committee can therefore consider the proposed strong password requirement alongside MFA and secure password management and recommend best approach.

Task 5 Governance Maturity Assessment

14.

Assessment	Current level	Reason
Policy & Documentation	2 – Initial	The policies exists but mostly are not up to date.
Roles & Responsibilities	1 – Ad Hoc	Accountability not clear
Risk Management	1 – Ad Hoc	Lack proactive assessment process.
Metrics & Reporting	2 – Initial	The metrics are not translated into business impact
Training & Awareness	2 – Initial	Annual training is mandatory, but there is low engagement.
Compliance	2 – Initial	The compliance is not monitored continuously

My assessment puts GHC mainly between Level 1 (Ad Hoc) and Level 2 (Initial). The most serious weaknesses are in roles and responsibilities and risk management, both of which are currently assessed at Level 1. Policies, reporting, training and compliance have some processes in place, but they are not documented adequately, standardised or monitored. This maturity level is not sufficient for an organisation handling sensitive health information while also growing through new markets, acquisitions and innovation.